AEGIS Report — 192.168.64.7

2026-10-11 16:49:05

AEGIS Report

Цель: 192.168.64.7 **Дата:** 2026-10-11 16:49:05 **Инструмент:** AEGIS Web v2.0

---

1. Разведка

Результаты nmap

Nmap scan report for 192.168.64.7 PORT STATE SERVICE VERSION 21/tcp open ftp vsftpd 2.3.4 22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0) 23/tcp open telnet Linux telnetd 25/tcp open smtp Postfix smtpd 53/tcp open domain ISC BIND 9.4.2 80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2) 111/tcp open rpcbind 2 (RPC #100000) 139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP) 445/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP) 513/tcp open login 514/tcp open tcpwrapped 2049/tcp open nfs 2-4 (RPC #100003) 2121/tcp open ftp ProFTPD 1.3.1 3306/tcp open mysql MySQL 5.0.51a-3ubuntu5 5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7 5900/tcp open vnc VNC (protocol 3.3) 6000/tcp open X11 (access denied) 8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
—

2. Анализ (LLM)

1. Список запущенных сервисов — строго по nmap-выводу, без переписывания версий:

- FTP (vsftpd 2.3.4)
- SSH (OpenSSH 4.7p1)
- Telnet
- SMTP (Postfix smtpd)
- DNS (ISC BIND 9.4.2)
- HTTP (Apache httpd 2.2.8)
- RPC (rpcbind 2)
- Samba (smbd 3.X - 4.X)
- Login
- NFS (2-4)
- FTP (ProFTPD 1.3.1)
- MySQL (MySQL 5.0.51a)
- PostgreSQL (PostgreSQL DB 8.3.0 - 8.3.7)
- VNC (protocol 3.3)
- X11
- AJP13

2. Реальные CVE — только из секции “CVE ИЗ БАЗЫ”:

- CVE-2011-2523 (vsftpd 2.3.4 backdoor)
- CVE-2016-0777 (OpenSSH client roaming)

- CVE-2018-15473 (OpenSSH < 7.7 user enumeration)
- CVE-2022-39028 (telnetd NULL pointer dereference)
- CVE-2021-27171 (FiberHome HG6245D devices root telnetd)
- CVE-2024-27305 (aiosmtpd SMTP smuggling)
- CVE-2023-51764 (Postfix SMTP smuggling)
- CVE-2008-0122 (BIND 9.4.x off-by-one DoS)
- CVE-2017-7659 (Apache 2.2.x DoS via malformed HTTP/2 request)
- CVE-2010-4221 (ProFTPD 1.3.1 stack overflow RCE)
- CVE-2012-2122 (MySQL 5.0.x/5.1.x/5.5.x authentication bypass)
- CVE-2013-1900 (PostgreSQL 8.3.x memory leak)
- CVE-2006-2369 (RealVNC 4.1.1 authentication bypass)

3. Векторы атаки — по приоритету (какие сервисы эксплуатировать первыми):

1. **FTP (vsftpd 2.3.4)** — CVE-2011-2523 (backdoor). Эксплуатация этого CVE дает прямой доступ к системе.
2. **MySQL (MySQL 5.0.51a)** — CVE-2012-2122 (authentication bypass). Эксплуатация этого CVE позволяет обойти аутентификацию.
3. **PostgreSQL (PostgreSQL DB 8.3.0 - 8.3.7)** — CVE-2013-1900 (memory leak). Эксплуатация этого CVE может привести к утечке памяти.
4. **ProFTPD 1.3.1** — CVE-2010-4221 (stack overflow RCE). Эксплуатация этого CVE дает прямой доступ к системе.
5. **OpenSSH 4.7p1** — CVE-2016-0777 (client roaming) и CVE-2018-15473 (user enumeration). Эксплуатация этих CVE может привести к утечке приватного ключа и информации о пользователях.
6. **Apache httpd 2.2.8** — CVE-2017-7659 (DoS via malformed HTTP/2 request). Эксплуатация этого CVE может привести к отказу в обслуживании.
7. **BIND 9.4.2** — CVE-2008-0122 (off-by-one DoS). Эксплуатация этого CVE может привести к отказу в обслуживании.
8. **telnetd** — CVE-2022-39028 (NULL pointer dereference) и CVE-2021-27171 (FiberHome HG6245D devices root telnetd). Эксплуатация этих CVE может привести к прямому доступу к системе.
9. **Postfix smtpd** — CVE-2024-27305 (SMTP smuggling) и CVE-2023-51764 (Postfix SMTP smuggling). Эксплуатация этих CVE может привести к утечке данных.
10. **NFS (2-4)** — Эксплуатация NFS может привести к утечке данных и привилегированным доступам.
11. **VNC (protocol 3.3)** — CVE-2006-2369 (authentication bypass). Эксплуатация этого CVE может привести к прямому доступу к системе.
12. **AJP13** — Эксплуатация AJP13 может привести к утечке данных и привилегированным доступам.

4. Рекомендации по защите — конкретные для найденных версий:

1. **vsftpd 2.3.4**: Обновите до версии 3.0.3 или выше.
2. **OpenSSH 4.7p1**: Обновите до версии 7.7p1 или выше.
3. **Apache httpd 2.2.8**: Обновите до версии 2.4.50 или выше.
4. **BIND 9.4.2**: Обновите до версии 9.14.0 или выше.
5. **telnetd**: Удалите telnetd, используйте SSH вместо него.
6. **Postfix smtpd**: Обновите до версии 3.8.6 или выше.
7. **NFS (2-4)**: Настройте строгие права доступа и используйте NFSv4.
8. **VNC (protocol 3.3)**: Обновите до версии 5.0 или выше.
9. **AJP13**: Настройте строгие права доступа и используйте безопасные протоколы.

Эти меры помогут уменьшить угрозы, связанные с найденными уязвимостями.

2.5. CVE по сервисам

Порт	Сервис	CVE	Max CVSS	Топ CVE
21	ftp	1	CRIT 10.0	CVE-2011-2523
22	ssh	2	MED 6.5	CVE-2016-0777, CVE-2018-15473
23	telnet	2	CRIT 9.8	CVE-2021-27171, CVE-2022-39028
25	smtp	2	MED 5.3	CVE-2023-51764, CVE-2024-27305
53	domain	1	MED 5.0	CVE-2008-0122
80	http	1	HIGH 7.5	CVE-2017-7659
2121	ftp	1	CRIT 10.0	CVE-2010-4221
3306	mysql	1	MED 5.1	CVE-2012-2122
5432	postgresql	1	MED 4.9	CVE-2013-1900
5900	vnc	1	HIGH 7.5	CVE-2006-2369

---

3. Эксплуатация уязвимостей

3.1. vsftpd 2.3.4 backdoor (root shell на 6200)

CVE: CVE-2011-2523
Порт: 21
Версия: vsftpd 2.3.4
Результат: УСПЕШНО

```
[*] vsftpd 2.3.4 backdoor on 192.168.64.7:21
[+] FTP banner: 220 (vsFTPd 2.3.4)
[+] USER resp: 331 Please specify the password.
[!] нет ответа на PASS (ожидаемо)
[+] Backdoor shell открыт на 192.168.64.7:6200 (attempt 1)
[+] Output: uid=0(root) gid=0(root)
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
root
[+] RCE подтверждён — root shell работает
```

3.2. VNC без пароля (доступ к экрану)

CVE: CVE-2006-2369
Порт: 5900
Версия: VNC (protocol 3.3)
Результат: НЕ СРАБОТАЛО

```
[*] VNC no-auth check on 192.168.64.7:5900
[+] VNC banner: b'RFB 003.003\n'
[+] Security type: 2
```

4. Взломанные учётные данные

Пользователь	Пароль
sys	batman
klog	123456789
msfadmin	msfadmin
postgres	postgres
user	user
service	service

Loot: /Users/arsenijselkonogov/Projects/aegis/loot/192_168_64_7_20261011_164658

5. Проверка сервисов

Скрипты не генерировались.

---

6. Сводная таблица портов

Порт	Сервис	Версия
21	ftp	vsftpd 2.3.4
22	ssh	OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23	telnet	Linux telnetd
25	smtp	Postfix smtpd
53	domain	ISC BIND 9.4.2
80	http	Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111	rpcbind	2 (RPC #100000)
139	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445	netbios-ssn	Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
513	login	
514	tcpwrapped	
2049	nfs	2-4 (RPC #100003)
2121	ftp	ProFTPD 1.3.1
3306	mysql	MySQL 5.0.51a-3ubuntu5
5432	postgresql	PostgreSQL DB 8.3.0 - 8.3.7
5900	vnc	VNC (protocol 3.3)
6000	X11	(access denied)
8009	ajp13	Apache Jserv (Protocol v1.3)

---

7. Рекомендации по защите

1. Обновить уязвимые сервисы до последних версий.
2. Настроить firewall — закрыть неиспользуемые порты.
3. Установить fail2ban для защиты от брутфорса.
4. Заменить Telnet на SSH.
5. Сменить все дефолтные пароли.
6. Провести аудит конфигураций.

AEGIS Web v2.0 — Autonomous Exploitation & Guidance Intelligence System. **Только для авторизованного пентеста.**